

Patching Challenges at Scale

Managing patches across 3 datacenters with diverse technology stacks presents unique challenges in coordination, risk management, and operational continuity.

3

Datacenters

6+

Technology
Domains

1000s

Endpoints
to Patch

24/7

Uptime
Requirement



Networking

Cisco IOS/
IOS-XE/NX-
OS
firmware
updates
Palo Alto
PAN-OS
upgrades
F5 BIG-IP
TMOS
patches
SD-WAN
controller
updates



Collaboration

Cisco UCM/
CUCM version
upgrades
Expressway/
VCS gateway
patches
Unity
Connection
updates
Webex
endpoints
firmware
SBC (Session
Border



HCI (Hyper- Converged Infrastructure)

Nutanix
AOS/AHV
upgrades
Nutanix
Prism
Central
patches
VMware
ESXi/
vCenter
updates
Firmware
(BIOS,



Security Products

Trellix/
McAfee EPO
& DAT
updates
CrowdStrike
Falcon
sensor
updates
Firewall
signature
updates
(IPS/IDS)



Monitoring Tools

SolarWinds
Orion
platform
updates
Splunk
forwarder/
indexer
patches
Nagios/
Zabbix core
upgrades
PRTG sensor



Microsoft Ecosystem

Windows
Server
monthly
patches
(WSUS)
Active
Directory
DC
updates
Exchange
Server CUs
& SUs

Key Challenges

Coordination Complexity

Scheduling
maintenance windows
across 3 DCs with
different time zones
and SLA requirements



Cybersecurity Requirements

Enterprise patching must comply with strict cybersecurity frameworks and standards to maintain security posture and regulatory compliance.



Regulatory & Compliance

ISO 27001 -
Information
Security
Management

NIST CSF -
Cybersecurity
Framework

PCI-DSS -
Payment Card
Industry
Standards

CIS Controls -
Center for
Internet Security
Benchmarks



Patch SLA Requirements

Severity	SLA	Scope
Critical (CVSS 9.0+)	24-72 hours	Internet-facing systems
Critical (CVSS 9.0+)	7 days	Internal systems
High (CVSS 7.0-8.9)	14 days	All systems
Medium (CVSS 4.0-6.9)	30 days	All systems
Low (CVSS 1.0-3.9)	90 days	Next maintenance





Security Controls for Patching

Network

Segmentation -

Isolated patch delivery network

Integrity

Verification -

Hash/signature validation for all patches

Least Privilege -

Minimal access for patch deployment accounts

Audit Trail - Full

logging of patch activities (who, what, when)

Change

Management -

CAB approval for production patches



Continuous Monitoring

Vulnerability

Management - Qualys/

Tenable/Rapid7 scanning

Patch Compliance

Reporting - Dashboard

with real-time status

Threat Intelligence

Feeds - Zero-day

awareness and prioritization

Asset Inventory - CMDB

accuracy for patch targeting

Exception Management

- Risk-accepted

unpatched systems tracking

KPI Metrics - Mean time

to patch, compliance percentage



Zero Trust Patching Principles

Never
Trust
Always
Verify

Verify
Patch
Integrity

Measure
Assess
Patch
Track

Risk, Human Error & Lessons Learned

Real-world incidents demonstrate why manual patching at scale is unsustainable. Automation reduces human error and ensures consistency across environments.



Real-World Incidents - Manual Patching Failures

Equifax Breach (2017)

Failed to patch Apache Struts CVE-2017-5638. Manual process missed critical server. 147M records exposed. Cost: \$1.4B+

WannaCry Ransomware (2017)

MS17-010 patch available 2 months before attack. Manual deployment too slow. 200K+



Human Error at Scale

Missed Systems - Incomplete asset inventory leads to unpatched servers

Wrong Patch Applied - Version mismatch on production systems

Skipped Testing - Pressure to meet SLA bypasses QA

Incorrect Sequence - Dependency order violated causing outages

Forgotten Rollback - No pre-patch snapshot taken

Credential Exposure - Admin passwords shared for manual patching

Documentation Gaps - Post-patch validation not recorded

Communication Failure - Team unaware of ongoing patch activity



Why Automated Updates Win

Factor	Manual	Automated
Consistency	Varies by engineer	100% repeatable
Speed	Days to weeks	Hours to minutes
Audit Trail	Incomplete logs	Full automation logs
Coverage	Missed systems	Complete inventory

Key Lessons & Mitigations

Staged Rollouts

Deploy to dev/test
staging → 10% canary
full production. Never
push to all systems
simultaneously.

Integrity Ver

Validate hash
signature of e
patch before
deployment. I
download thr
secure pull
architecture.



Secure Pull Architecture - 5 Layer Security

The Secure Pull model ensures all patch/update traffic flows through 5 distinct security layers, each enforcing strict isolation and inspection of DMZ VMs and traffic.





DC Firewall



- Datacenter Firewall for internal east-west traffic
- Source & Destination IP Whitelisting
 - Only specific DC servers → specific DMZ servers
- IPS, Zoning & Multi-Instance
- Unidirectional Flow from DC to DMZ



ACI Fabric



- Cisco ACI micro-segmentation at fabric level
- Source Whitelisting – Only specific EPG to DMZ
- Service Graphs, PBR, VRFs
- EPGs, ESGs & Multi-tenancy
- Unidirectional Flow from EPG to DMZ

DMZ Zone Security

DMZ VMs completely isolated from internal DC network

No direct internet access for DMZ servers

All external communication via proxy only

Patch downloads pulled through

DC Zone Security

DC servers initiate pull requests to DMZ staging servers

No direct DMZ-to-DC traffic allowed (unidirectional)

ACI fabric enforces micro-segmentation per application

Service graphs route traffic through inspection points



Update Types & Technologies

Different products require different update mechanisms, repositories, and validation methods. The Secure Pull architecture supports all update types through unified secure channels.



WSUS (Windows Updates)

Microsoft

Auto

Windows
Server
monthly
quality
updates
Cumulative
Updates (CUs)
Security-only
updates
Servicing
Stack Updates
(SSU)
.NET
Framework
patches
Feature
updates &



Ivanti (Patch Management)

Multi-Platform

Auto

Third-party
application
patches
Linux/Unix
system
patches
Custom
application
updates
Driver updates
BIOS/firmware
orchestration
Patch
compliance
reporting

Pull Method: Ivanti
console downloads
patches to DMZ



Nutanix (HCI Platform)

Infrastructure

Semi-Auto

AOS
(Acropolis
OS)
upgrades
AHV
hypervisor
updates
Prism
Central
patches
NCC
(Nutanix
Cluster
Check)
Foundation
updates
LCM (Life



Trellix (Endpoint Security)

Security

Auto

DAT/AMCore
content
updates
(hourly)
Engine
updates
(monthly)
EPO platform
patches
Product
hotfixes
Exploit
prevention
content
Threat
intelligence
feeds



Firewall Updates

Security

Semi-Auto

PAN-OS
software
upgrades
Threat
Prevention
signatures
(daily)
WildFire
updates (every
5 min)
URL filtering
database
GlobalProtect
agent updates
App-ID
signature
updates

Pull Method:



IAM PAM NAC

Identity

Manual+Auto

IAM: Azure
AD / Entra
ID sync
updates
PAM:
CyberArk
Vault/
CPM/PSM
patches
NAC: Cisco
ISE node
upgrades
Certificate
rotation &
renewal
MFA
provider
updates



Collaboration

Unified Comms

Manual

CUCM/UCM
major version
upgrades
COP file
installations
Expressway/
VCS patches



Microsoft Products

Enterprise

Auto+Manual

Exchange
Server CUs &
SUs
SQL Server
cumulative
updates



Mon & To

Operations

Manual

SolarWinds
Orion
platform
hotfixes
Splunk
forwarder/

Automated vs Manual Update Strategy

A hybrid approach balances speed and safety. Automated updates for routine content, manual staged rollouts for infrastructure-impacting changes.



Automated Updates (Scheduled/Continuous)

System	Update Type	Frequency
Trellix DAT/Signatures	Content update	Every 4 hours
Palo Alto WildFire	Threat signatures	Every 5 minutes
Palo Alto Threat Prevention	IPS signatures	Daily
Windows Defender definitions	AV signatures	Every 2 hours
WSUS security patches	OS patches	Monthly (Patch Tuesday)
CrowdStrike sensor	Agent update	Weekly (staged)
URL filtering DB	Category update	Daily
Certificate auto-renewal	PKI	30 days before expiry

Benefits: Zero human intervention, consistent timing, complete coverage, immediate threat response, reduced attack window

Manual Updates (CAB Approved)

System	Update Type	Caden
PAN-OS major upgrade	Firewall OS	Quart
Nutanix AOS upgrade	HCI platform	Bi-ann
CUCM version upgrade	Collab platform	Annual
Exchange CU	Email platform	Quart
Cisco ISE upgrade	NAC platform	Bi-ann
CyberArk PAM	Vault/CPM/PSM	Bi-ann
ACI fabric upgrade	Network fabric	Bi-ann
SQL Server CU	Database	Quart

Requirements: Change Advisory Board approval, maintenance window, rollback plan, pre/post



Update Workflow Pipeline

STEP 1

Vendor Release

Patch published to vendor portal/CDN

STEP 2

Secure Pull

Downloaded via proxy to DMZ staging

STEP 3

Integrity Check

Hash/signature verification

STEP 4

Lab/Dev Test

Deploy to non-prod first

STEP 5

Staged Rollout

Canary 25% 100%

STEP 6

Validation

Post-patch scanning & monitoring



Auto- Approved (Low Risk)

Antivirus
definition
updates
IPS/IDS
signature
updates
URL
category
database
refresh
Threat
intelligence
feeds
Endpoint
agent
minor
updates
Certificate
auto-
renewals

Semi- Automated (Medium Risk)

OS
security
patches
(monthly)
Application
patches
(scheduled)
Agent
major
version
upgrades
Plugin/
extension
updates
Driver
updates
Runtime/
framework
patches

Manual Only (High Risk)

Platform
major
upgrades
(CUCM,
ACI)
Database
engine
upgrades
Hypervisor
upgrades
(ESXi/
AHV)
Firewall
OS
major
versions
Identity
platform
upgrades



Secure Vendor Access - BeyondTrust PRA

BeyondTrust Privileged Remote Access (PRA) provides secure, audited vendor access for maintenance and patching activities without exposing internal credentials or infrastructure.

Why BeyondTrust PRA?

Zero Trust Access -

Vendors never get VPN or direct network access

Session Recording -

Full video recording of all vendor sessions

Credential Injection

- Vendors never see actual passwords

Time-Limited Access

- JIT (Just-In-Time) access with auto-expiry

Approval Workflow -

Multi-level approval before access granted

Granular

Permissions - Access only to specific systems needed

Without PRA (Traditional Risks)

Shared VPN credentials for vendor access

No visibility into vendor actions on systems

Persistent access not revoked after work

No session recording for audit

Vendor has broad network access via VPN

Credentials stored on vendor laptops

No approval workflow for access

Lateral movement risk if vendor compromised



BeyondTrust PRA - Vendor Access Flow

Vendor Request

Vendor requests access via PRA portal with justification

Approval

IT Security/Manager approves with time window

Secure Session

Vendor connects via PRA jump point (no VPN)

Credential Inject

PRA injects credentials (vendor never sees them)

Work Performed

Session recorded, keystrokes logged, screenshots captured

Auto-Terminate

Session ends at approved time. Access auto-revoked



Vendor Use Cases

Nutanix

Support

- AOS/
AHV
troubleshooting
&
upgrades

Cisco

TAC -

UCM/
ACI/ISE
remote
support

Palo

Alto -

Firewall
configuration
&
upgrades

CyberArk

- PAM
vault
maintenance

Microsoft

Premier

-
Exchange/
SQL
critical

Security Controls

MFA

Required

-
Vendor
must
authenticate
with
MFA

Geo-

restriction

-
Access
only
from
approved
countries

Protocol

Control

- Only
RDP/
SSH/
HTTPS
allowed

Clipboard

Disabled

- No
data
exfiltration
via
copy/

Compliance & Reporting

Session

Recordings

-
Stored
for 12
months
minimum

Access

Reports

- Who
accessed
what,
when,
for
how
long

Anomaly

Detection

- Alerts
on
unusual
vendor
behavior

Regulatory

Mapping

- ISO
27001,
NCA
ECC,
PCI



Architecture Integration

PRA Jump Points in DMZ

BeyondTrust jump points deployed in DMZ zone, accessible through Layer 3 (DMZ Firewall). Vendors connect to jump points which broker access to internal systems through controlled channels.

